

... REPORTE DE ACTIVIDAD 8

Nombre del proyecto: LAB: FILE PATH TRAVERSAL SEQUENCES BLOCKED
WITH ABSOLUTE PATH BYPASS

Nivel: Apprentice

Nombre: Karla Vanessa Glz Espinoza

TIPO DE EXPLOTACIÓN

Path Traversal (Directory Traversal) Bypass / CWE-22: Improper Limitation of a Pathname to a Restricted Directory.

OBJETIVO DEL LABORATORIO

El objetivo de este laboratorio es evadir los filtros de seguridad que bloquean secuencias de salto de directorio (como ../) explotando el uso inseguro de rutas relativas y absolutas, con el fin de acceder al archivo protegido /etc/passwd del servidor.

EXPLICACIÓN TÉCNICA

En un intento por mitigar los ataques básicos de Directory Traversal, los desarrolladores suelen implementar filtros de validación de entrada (input validation) que bloquean o eliminan las secuencias comunes de salto, tales como ../ o ../\ (OWASP Foundation, 2023). Sin embargo, si la aplicación toma el nombre del archivo proporcionado por el usuario y lo procesa asumiendo implícitamente que es relativo a un directorio de trabajo predeterminado (por ejemplo, pasando el parámetro directamente a una API del sistema de archivos como open()), el filtro resulta ineficaz frente a rutas absolutas. Una ruta absoluta es aquella que se especifica desde el nodo raíz de la jerarquía de archivos del sistema operativo, como /etc/passwd en sistemas UNIX o C:\Windows\win.ini en sistemas Windows (MITRE, 2023).

De acuerdo con CISA (2022), si no se valida explícitamente que la ruta canónica final resida dentro de los límites del directorio esperado, un atacante puede saltarse por completo el filtro de ../ simplemente suministrando la ruta absoluta directa al archivo objetivo.

PROCEDIMIENTO

Paso 1: Se inició el entorno de pruebas utilizando las credenciales provistas por Web Security Academy y se preparó Burp Suite Community Edition para interceptar el tráfico.

Paso 2: Al cargar la página de detalles de un producto, la aplicación web realiza solicitudes para obtener recursos estáticos. Se inspeccionó el tráfico en el historial HTTP de Burp Suite, localizando la petición a `/image?filename=7.jpg` y enviándola al módulo Repeater para manipular los datos de entrada de forma manual.

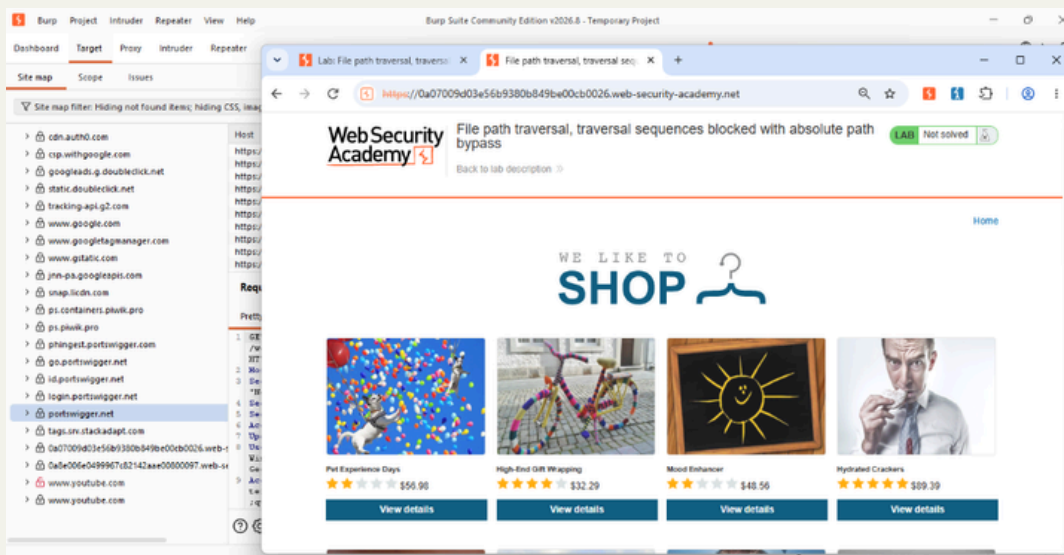


Figura 8.1 Pagina principal de la tienda en un apartado de “View details” de un producto.

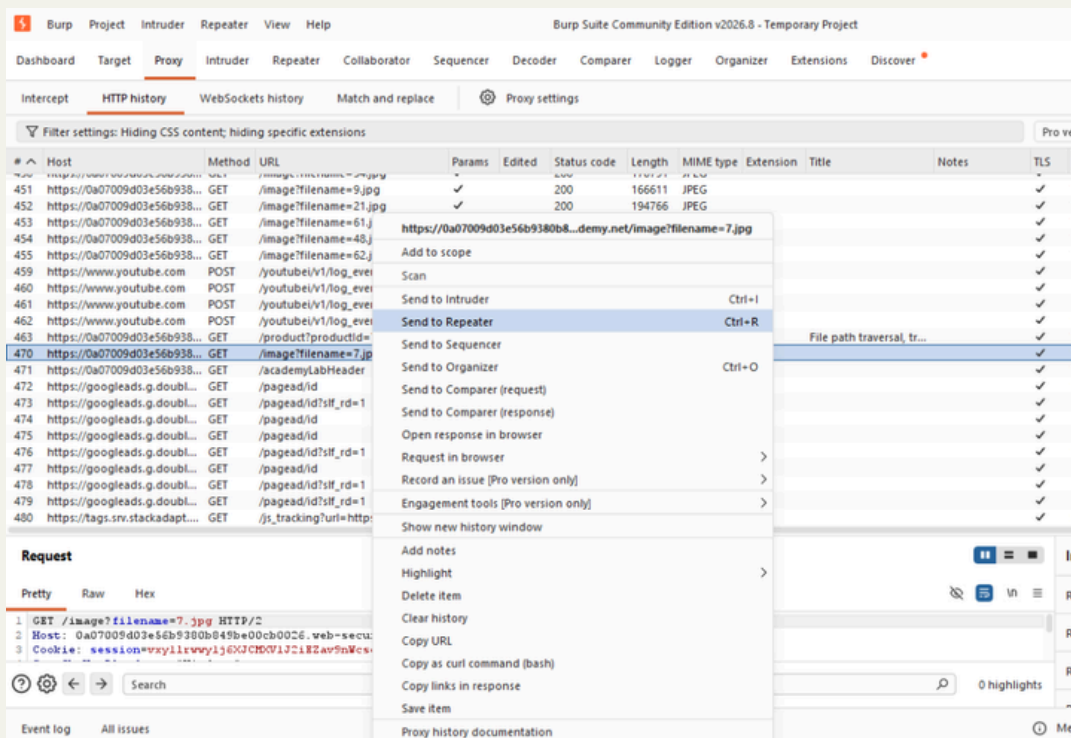


Figura 8.2 Se envió la petición a Repeater para su manipulación

Paso 3: Se preparó la petición dentro de Repeater para alterar el valor del parámetro filename, reconociendo que el uso de la secuencia ../ generaba un bloqueo por parte del servidor web.

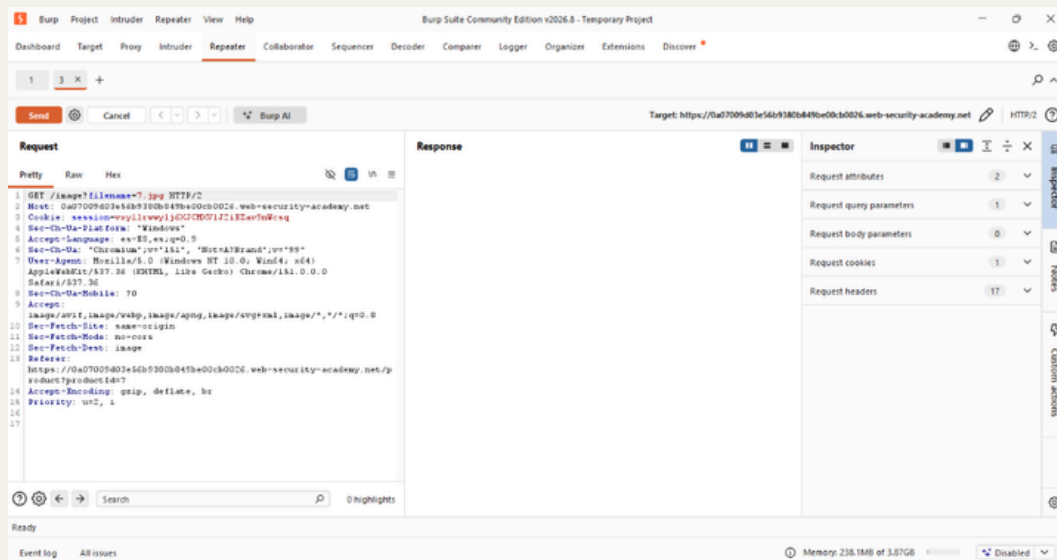


Figura 8.3 Parámetro filename original

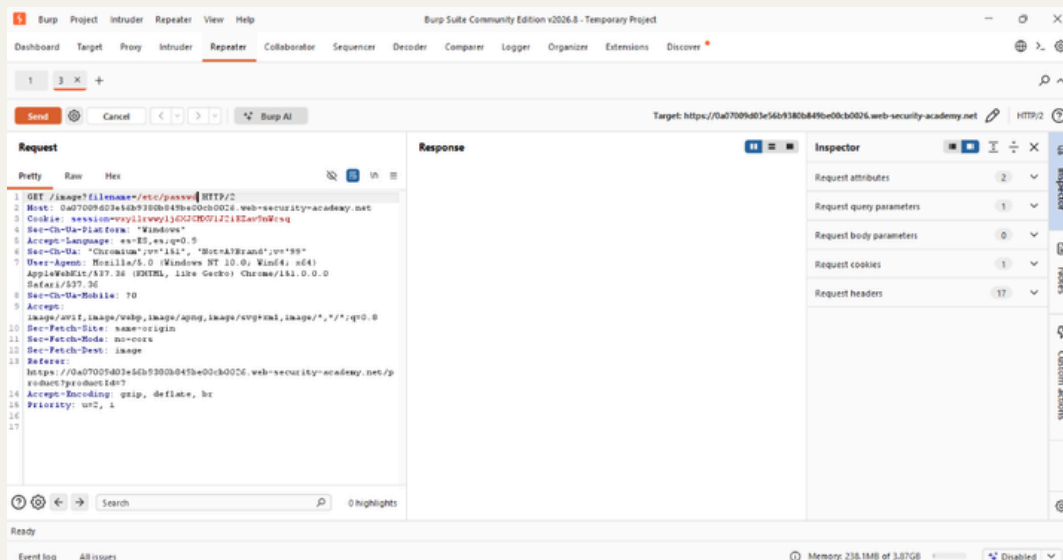


Figura 8.4 Parámetro filename modificado

Paso 4: Se evadió el filtro implementado sustituyendo la petición de archivo relativo por una ruta absoluta, inyectando el payload malicioso `/etc/passwd`. Al enviar la petición, se obtuvo el estado HTTP/2 200 OK revelando el contenido del archivo de usuarios del sistema Linux, demostrando la vulnerabilidad.

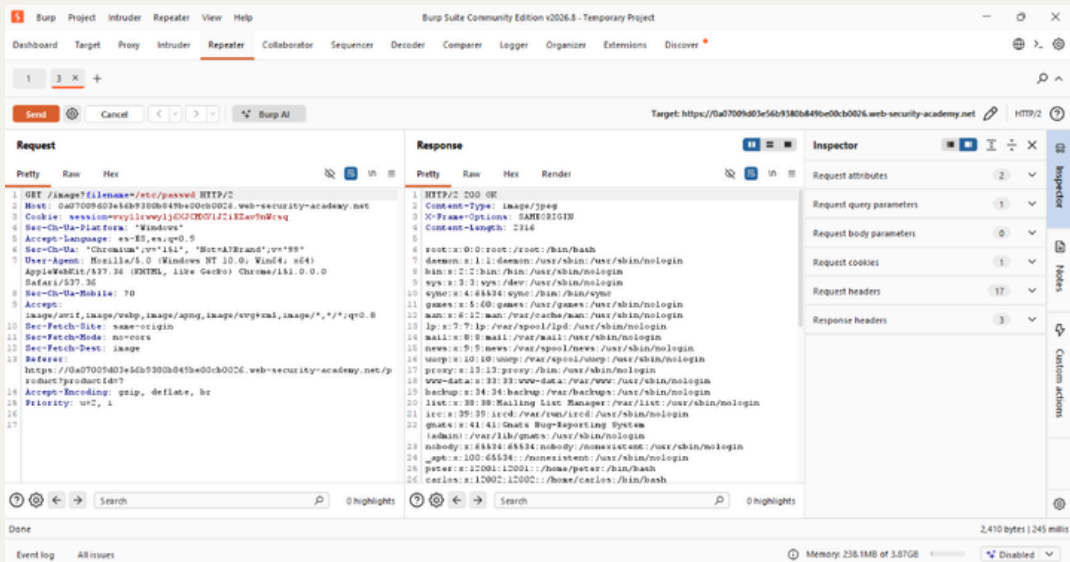


Figura 8.5 Respuesta del servidor al filename modificado

Paso 5: Se recargó la interfaz del navegador, validando exitosamente el compromiso del objetivo con el indicador visual "Lab Solved".

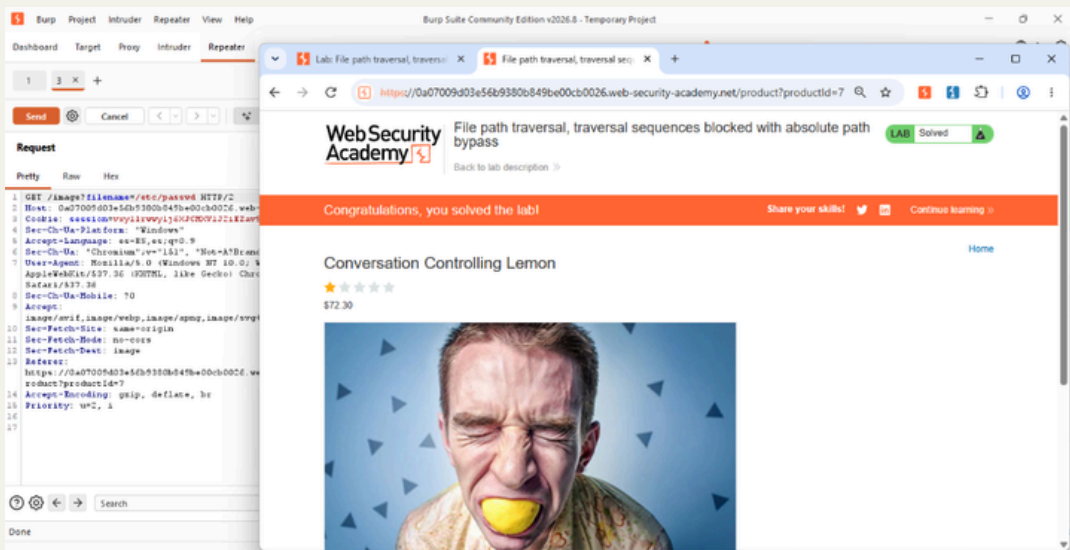


Figura 8.6 Laboratorio finalizado

EXPLICACIÓN DEL PAYLOAD

Payload utilizado: `/etc/passwd`

A diferencia del laboratorio anterior, la aplicación implementa una defensa que busca y bloquea secuencias de caracteres como `../`. No obstante, la función encargada de leer el archivo invoca APIs del sistema de archivos que aceptan tanto rutas relativas como absolutas.

Al proporcionar la ruta absoluta `/etc/passwd` (que inicia directamente en el directorio raíz del sistema operativo Linux), la aplicación no encuentra la cadena de escape bloqueada (`../`), por lo que aprueba la validación de seguridad. Posteriormente, el sistema operativo resuelve la ruta absoluta exactamente como se le solicita, obviando el directorio predeterminado de imágenes e ignorando los controles de aislamiento, entregando así el archivo confidencial.

MITIGACIÓN RECOMENDADA

- Evitar concatenaciones inseguras: Jamás pasar entradas del usuario directamente a las APIs de archivos (p. ej., `java.io.File`, `os.path.join`). Se deben emplear enfoques basados en identificadores indirectos estáticos almacenados en una base de datos (OWASP Foundation, 2023).
- Validación de nombre de archivo estricto (Allow-list): Si se requiere pasar el nombre de archivo, el backend debe aplicar expresiones regulares estrictas (regex) para garantizar que el valor contenga únicamente caracteres alfanuméricos válidos y extensiones permitidas, rechazando explícitamente el uso de `/` y `\`.
- Resolución de ruta canónica (Path Canonicalization): Se debe resolver la ruta de acceso final utilizando métodos seguros del framework para obtener la ruta absoluta y canonizada. Posteriormente, se debe implementar una condición estricta que valide que la ruta resuelta `startsWith()` (comienza exactamente con) la ruta base autorizada de almacenamiento del servidor antes de permitir el acceso al recurso (CISA, 2022).

REFERENCIAS

- CISA. (2022). Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal'). Cybersecurity and Infrastructure Security Agency. <https://www.cisa.gov/uscert/bsi/articles/knowledge/coding-practices/path-traversal>
- MITRE. (2023). CWE-22: Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal'). Common Weakness Enumeration. <https://cwe.mitre.org/data/definitions/22.html>
- OWASP Foundation. (2023). Path Traversal. Open Worldwide Application Security Project. https://owasp.org/www-community/attacks/Path_Traversal